

SGSI-REG-006 — Registro de No Conformidades, Deuda de Diseño y Acciones Correctivas

Organización: Atalaya Gestión Patrimonial SL

Código de documento	SGSI-REG-006
Versión	1.8
Estado	Vigente
Clasificación	Confidencial
Propietario	Dirección General — Atalaya GP SL
Autor	El consultor (externo)
Emisión v1.0	24/07/2026
Revisiones v1.1 a v1.7	24/07/2026, 20/08/2026 y 22/08/2026
Revisión v1.8	23/08/2026
Aprobación v1.8	— (pendiente; sometida a aprobación del Comité de Seguridad Convergente; v1.7 permanece vigente hasta entonces, SGSI-DOC-002 §3)

Objeto

Registro previsto en SGSI-DOC-010 §4. Recoge los incumplimientos de requisitos del SGSI, su análisis de causa y las acciones correctivas asociadas, con su verificación de eficacia (cláusula 10.2).

Dos hojas y por qué están separadas

«No conformidades» — Incumplimientos de un requisito del SGSI. En la fecha de emisión está vacía, y es correcto: el sistema se encuentra en implantación y la primera auditoría interna está planificada para el primer semestre de 2027. «Deuda de diseño» — Hallazgos del propio proceso de construcción del SGSI, registrados en SGSI-DOC-010 §4.1. NO son no conformidades: un control planificado que aún no opera no incumple ningún requisito.

Reglas de uso

- Una acción sin verificación de eficacia no cierra la no conformidad: la esconde. El campo de verificación es obligatorio.
- El análisis de causa pregunta qué del sistema permitió el fallo, no quién falló (regla de no represalia, DOC-003).
- Si la causa apunta a un escenario mal valorado, obliga a re-evaluarlo (DOC-004 §8) y a registrarlo en la columna correspondiente.
- Primero se contiene el efecto, después se analiza la causa.
- Regla de conversión: vencido el plazo de una entrada de deuda de diseño sin cierre acreditado, esa entrada SÍ constituye no conformidad y se da de alta en la hoja «No conformidades» con el procedimiento completo de DOC-010 §4.

Historial de versiones

Versión	Fecha	Descripción del cambio
1.6	20/08/2026	Alta de la entrada HD-08 en esta hoja (el MSP opera como encargado del tratamiento de facto sin contrato conforme al art. 28 RGPD), reflejada también en SGSI-DOC-010 v1.9 §4.1. Hallazgo identificado al construir SGSI-REG-008, tratamiento T-10.
1.7	22/08/2026	Ampliación del alcance de HD-01, que pasa de doce a trece controles con el alta de A 8.21, retirado de su anexo de soporte contractual en SGSI-DOC-006 v1.5.
1.8	23/08/2026	HD-08: se anota el alta del borrador SGSI-ACU-003 v0.1 (anexo de encargado del tratamiento con el MSP, art. 28 RGPD), redactado el 23/08/2026 y pendiente de aprobación del Comité y de firma por el MSP. El hallazgo NO se cierra: conforme a la regla de uso 1 de esta misma hoja («una acción sin verificación de eficacia no cierra la no conformidad, la esconde») y a DOC-010 §4, el borrador no es la acción determinada —

Historial completo v1.0-1.5 en SGSI-REG-006 v1.7 (sin cambios respecto de esa versión).

ID	Fecha detección	Origen	Clasificación	Descripción del incumplimiento	Requisito incumplido	Reacción inmediata	Análisis de causa	Acción correctiva	Responsable	Plazo	Verificación de eficacia	Fecha verificación	Estado	¿Obliga a re-evaluar escenario?	HD de origen
NC-2027-001 (ejemplo)		Revisión de registros	Menor	Ejemplo de formato. Sustituyase por una no conformidad real.	Clausula o control del Anexo A	Qué se hizo para contener el efecto antes de analizar la causa.	Qué del sistema permitió el fallo. No quién falló.	Acción dirigida a la causa, no al síntoma.	Rol responsable	dd/mm/aaaa	Cómo se comprueba que la acción funcionó, vencido el plazo.	dd/mm/aaaa	Abierta		

ID	Fecha alta	Hallazgo	Origen del hallazgo	Tratamiento comprometido	Responsable	Plazo	Estado	Fecha de cierre	Si vence sin cierre
HD-01	24/07/2026	Trece controles del Anexo A declarados aplicables descansan en una práctica no escrita, sin documento del SGSI ni control del registro que los soporte: A 5.6, 5.29, 5.32, 6.1, 6.2, 7.5, 7.11, 8.6, 8.7, 8.12, 8.19, 8.21 y 8.23.	Trazabilidad de la Declaración de Aplicabilidad (SGSI-REG-003, columna «Controles»).	Asignar a cada uno un documento o un control del registro, o reclasificar su aplicabilidad con justificación escrita.	Responsable del SGSI	24/10/2026	Abierta		Alta como no conformidad menor por incumplimiento de la cláusula 8.1: los controles están determinados, justificados y con su estado declarado en la Declaración de Aplicabilidad, que es lo que exige 6.1.3
HD-02	24/07/2026	Dos escenarios de nivel Alto no alcanzan la cobertura convergente exigida en SGSI-DOC-004 §6 con el tratamiento diseñado: RSC-004 no tiene previsto ningún control en el dominio físico y RSC-016 se trata con un único control organizativo.	Verificación de la regla de convergencia sobre el registro v1.1.	Rediseñar el tratamiento incorporando el control que falta en cada dominio, o documentar la excepción ante el Comité con justificación escrita.	Propietarios de los riesgos	24/09/2026	Abierta		Alta como no conformidad menor por incumplimiento de la metodología aprobada.
HD-03	24/07/2026	Existen controles físicos contratados y operativos cuya ejecución no deja evidencia registrada, por lo que su eficacia no es verificable (RSC-018).	Aportación del jefe de seguridad en la revisión del catálogo de escenarios.	Implantar los registros de ejecución previstos en PT-11 y medir su cumplimiento mediante el objetivo O8 (DOC-005).	Jefe de seguridad	24/09/2026	Abierta		Alta como no conformidad mayor: afecta a controles de riesgos de nivel Crítico.
HD-04	24/07/2026	Cinco escenarios del registro no se situaban en ninguna interfaz declarada del alcance, incumpliendo la regla de completitud de SGSI-DOC-004 §5.1.	Verificación cruzada entre SGSI-REG-001 y SGSI-DOC-001 §7.4.	Corregido en dos pasos: alta de cuatro interfaces en SGSI-DOC-001 §7.4 y normalización de la columna «Interfaz» de SGSI-REG-001 al vocabulario de las diez interfaces declaradas.	Responsable del SGSI	30/09/2026	Cerrada	24/07/2026	No procede: hallazgo cerrado.
HD-05	24/07/2026	Cuatro escenarios carecían de objetivo de seguridad asociado, dos de ellos desde la primera versión del cuadro de objetivos.	Verificación cruzada entre SGSI-REG-001 y SGSI-DOC-005.	Corregido en la propia revisión mediante el alta de los objetivos O11 y O12 en SGSI-DOC-005.	Comité de Seguridad Convergente	30/09/2026	Cerrada	24/07/2026	No procede: hallazgo cerrado.
HD-06	24/07/2026	La Declaración de Aplicabilidad y el registro de riesgos empleaban vocabularios de estado distintos, y cinco controles del Anexo A figuraban como implantados mientras los controles del registro que los soportan estaban planificados.	Verificación cruzada entre SGSI-REG-003 y SGSI-REG-001 (hoja «Controles»).	Vocabulario unificado y regla de coherencia declarada en ambos documentos. Pendiente de incorporar la comprobación al validador automático.	Responsable del SGSI	24/10/2026	Abierta		Alta como no conformidad menor: la comprobación automática de coherencia seguiría sin existir.
HD-07	20/08/2026	La clasificación de SGSI-REG-001 (Confidencial) no era coherente con su propio contenido: la portada declara «la relación completa de vulnerabilidades del sistema de protección de la familia», definición literal de Restringida en SGSI-DOC-002 §5. El mismo desajuste afectaba a esta hoja y a SGSI-DOC-010 §4.1.	Revisión de clasificación de agosto de 2026, por aplicación de la regla del nivel superior de SGSI-DOC-002 §5.	Reclasificado SGSI-REG-001 a Restringida y SGSI-REG-006 y SGSI-DOC-010 a Confidencial, en esta misma revisión.	Responsable del SGSI	20/08/2026	Cerrada	20/08/2026	No procede: hallazgo cerrado.
HD-08	20/08/2026	El MSP administra correo corporativo (M365), NAS doméstico con documentación familiar y CCTV con acceso administrativo pleno (DOC-006 §5), pero no consta contrato de encargo del tratamiento conforme al art. 28 RGPD que regule esa relación. Como consecuencia directa, tampoco consta verificada la región de alojamiento del tenant M365 ni, si procede, las garantías del art. 46 RGPD para una eventual transferencia internacional. [v1.8] Actualización de estado: SGSI-ACU-003 v0.1 (borrador del anexo) redactado el 23/08/2026, con los controles del Anexo A corregidos frente a la trazabilidad vigente de DOC-006 §5 (5.21, 5.22, 5.23, 7.10, 7.14, 8.2, 8.9, 8.15, 8.17, 8.22) y sin ampliar el diseño de segmentación de red más allá de lo ya aprobado. Pendiente: aprobación del Comité, negociación y firma por el MSP, y verificación de eficacia. El hallazgo NO se cierra con la sola redacción del borrador.	Construcción de SGSI-REG-008 (Registro de Actividades de Tratamiento), tratamiento T-10.	Formalizar contrato o anexo de encargo del tratamiento con el MSP (objeto, duración, obligaciones del art. 28.3, sub-encargados, medidas de seguridad, destino de los datos a la finalización) y confirmar la región de alojamiento del tenant M365. Borrador en curso: SGSI-ACU-003 v0.1.	Dirección General	20/11/2026	Abierta		Alta como no conformidad menor por incumplimiento del art. 28 RGPD (relación con encargo del tratamiento sin contrato) y de la cláusula 8.1 (acción determinada no implementada).